

6 Static Code Analysis

Performed by *Nikita Niakhai*

Bellow there are projects and tools I picked up.

Tool	Language	Name of project
SNYK	PHP	DVWA
Deepsources	NodeJs	DVNA

1. Signed up on all tools
2. Copied 3 repositories to my account in order to access them.

```
vaper@NIKITA MINGW64 /y/MEGA/SNE-25/2_ComSysNet/1_Labs/6/Projects to Analyze
$ git clone https://github.com/appsecco/dvja
Cloning into 'dvja'...
remote: Enumerating objects: 256, done.
remote: Total 256 (delta 0), reused 0 (delta 0), pack-reused 256 (from 1)
Receiving objects: 100% (256/256), 1.17 MiB | 81.00 KiB/s, done.
Resolving deltas: 100% (54/54), done.

vaper@NIKITA MINGW64 /y/MEGA/SNE-25/2_ComSysNet/1_Labs/6/Projects to Analyze
$ git clone https://github.com/digininja/DVWA
Cloning into 'DVWA'...
remote: Enumerating objects: 5595, done.
remote: Counting objects: 100% (66/66), done.
remote: Compressing objects: 100% (31/31), done.
remote: Total 5595 (delta 50), reused 37 (delta 35), pack-reused 5529 (from 3)
Receiving objects: 100% (5595/5595), 2.64 MiB | 132.00 KiB/s, done.
Resolving deltas: 100% (2781/2781), done.

vaper@NIKITA MINGW64 /y/MEGA/SNE-25/2_ComSysNet/1_Labs/6/Projects to Analyze
$ git clone https://github.com/appsecco/dvna
Cloning into 'dvna'...
remote: Enumerating objects: 645, done.
remote: Total 645 (delta 0), reused 0 (delta 0), pack-reused 645 (from 1)
Receiving objects: 100% (645/645), 3.18 MiB | 91.00 KiB/s, done.
Resolving deltas: 100% (281/281), done.
```

```
vaper@NIKITA MINGW64 /y/MEGA/SNE-25/2_ComSysNet/1_Labs/6/Projects to Analyze/dvna (main)
$ git push origin main
Enumerating objects: 474, done.
Counting objects: 100% (474/474), done.
Delta compression using up to 12 threads
Compressing objects: 100% (290/290), done.
Writing objects: 100% (474/474), 3.15 MiB | 794.00 KiB/s, done.
Total 474 (delta 178), reused 474 (delta 178), pack-reused 0 (from 0)
remote: Resolving deltas: 100% (178/178), done.
To https://github.com/NikitaNekhay/DVNA-clone.git
 * [new branch]      main -> main
```

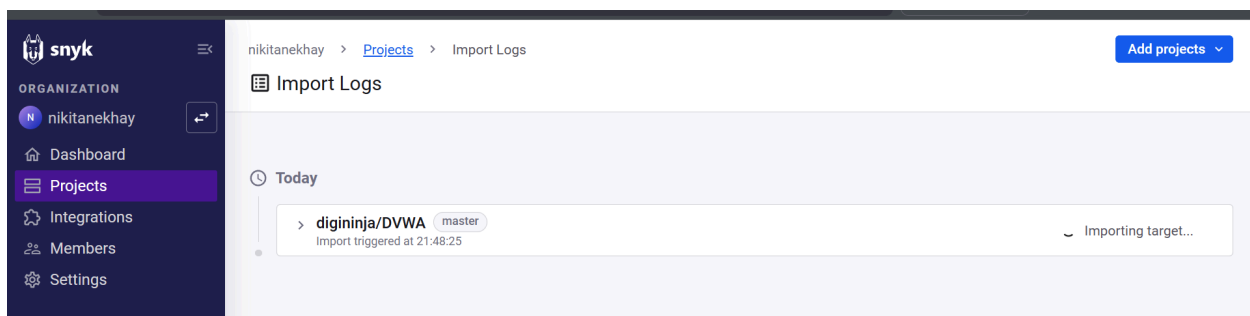
3. Used commands:

```
git remote set-url origin git@github.com:username/repo.git
```

- Get original repo's HTTPS clone URL (Code button).
- Create a new repository on your GitHub account.
- Clone it locally using `git clone <URL>`.
- Navigate to the local directory (`cd`).
- Initialize Git (`git init` if needed).
- Add all files (`git add .`).
- Commit changes (`git commit -m "Initial commit"`).
- Push to your new repo (`git push origin main`).

`git remote set-url origin git@github.com:NikitaNekhay/DVNA-clone.git`

DVWA



1. Imported public repo

Top vulnerable projects ②			
Project	Tested	Issues	Actions
 digininja/DVWA	7 minutes ago	0  40  30  39 	
Showing 1-1 of 1			

2. After that system has analysed the code

Issues 109

SEVERITY

☐ High 40

☐ Medium 30

☐ Low 39

PRIORITY SCORE

Scored between 0 - 1000

STATUS

☒ Open 109

☐ Ignored 0

LANGUAGES

☐ PHP 108

☐ JavaScript 1

VULNERABILITY TYPES

☐ Use of Password Hash... 23

☐ Information Exposure -... 23

☐ SQL Injection 13

☐ Path Traversal 8

☐ Command Injection 7

☒ Cross-site Scripting (XSS) 6

☐ Sensitive Cookie in HTT... 5

☐ Hardcoded Non-Cryptog... 5

6 of 109 Issues

H

Cross-site Scripting (XSS) 

SNYK CODE | CWE-79 

```
385 Header( 'Cache-Control: no-cache, must-revalidate'); // HTTP/1.1
386 Header( 'Content-Type: text/html; charset=utf-8' ); // TODO- proper XHTML headers...
387 Header( 'Expires: Tue, 23 Jun 2009 12:00:00 GMT' ); // Date in the past
388
389 echo "<!DOCTYPE html";
```

Unsanitized input from *cookies* flows into *the echo statement*, where it is used to render an HTML page returned to the user. This may result in a Cross-Site Scripting attack (XSS).

[dwwa/includes/dvwaPage.inc.php](#) 

[Learn about this type of vulnerability and how to fix it](#) 

H

Cross-site Scripting (XSS) 

SNYK CODE | CWE-79 

```
457 Header( 'Cache-Control: no-cache, must-revalidate'); // HTTP/1.1
458 Header( 'Content-Type: text/html; charset=utf-8' ); // TODO- proper XHTML headers...
459 Header( 'Expires: Tue, 23 Jun 2009 12:00:00 GMT' ); // Date in the past
460
461 echo "<!DOCTYPE html";
```

Unsanitized input from *cookies* flows into *the echo statement*, where it is used to render an HTML page returned to the user. This may result in a Cross-Site Scripting attack (XSS).

[dwwa/includes/dvwaPage.inc.php](#) 

[Learn about this type of vulnerability and how to fix it](#) 

3. I clicked on the vulnerable project and saw the overview. On the left side on interface there are different options to filter issues by language/vulnerability type/severity. On the right side is a list of issues: line of code, file, good description and knowledge abilities, that are linked to Snyk Learn platform.

6 Static Code Analysis

3

H

Cross-site Scripting (XSS) [🔗](#)

SNYK CODE

CWE-79 [🔗](#)

SCORE

755

Why this Priority Score?

- Found in multiple sources
- Found in multiple code flows
- Has fix examples available

24

25

26

<button onclick="\self.close();\">Close</button>;

27

The priority score

Data flow

Fix analysis

×

Example fixes ⓘ

pimcore/pimcore

◀ 1 / 3 ▶

5

—<title><?php echo \$_SERVER["HTTP_HOST"] ?> :: Pimcore</

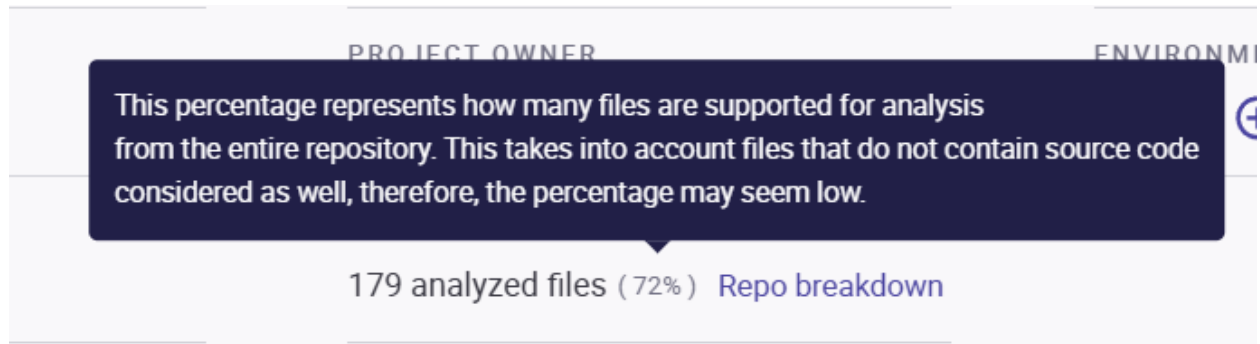
5+

<title><?php echo htmlentities(\$_SERVER["HTTP_HOST"], E

6

6

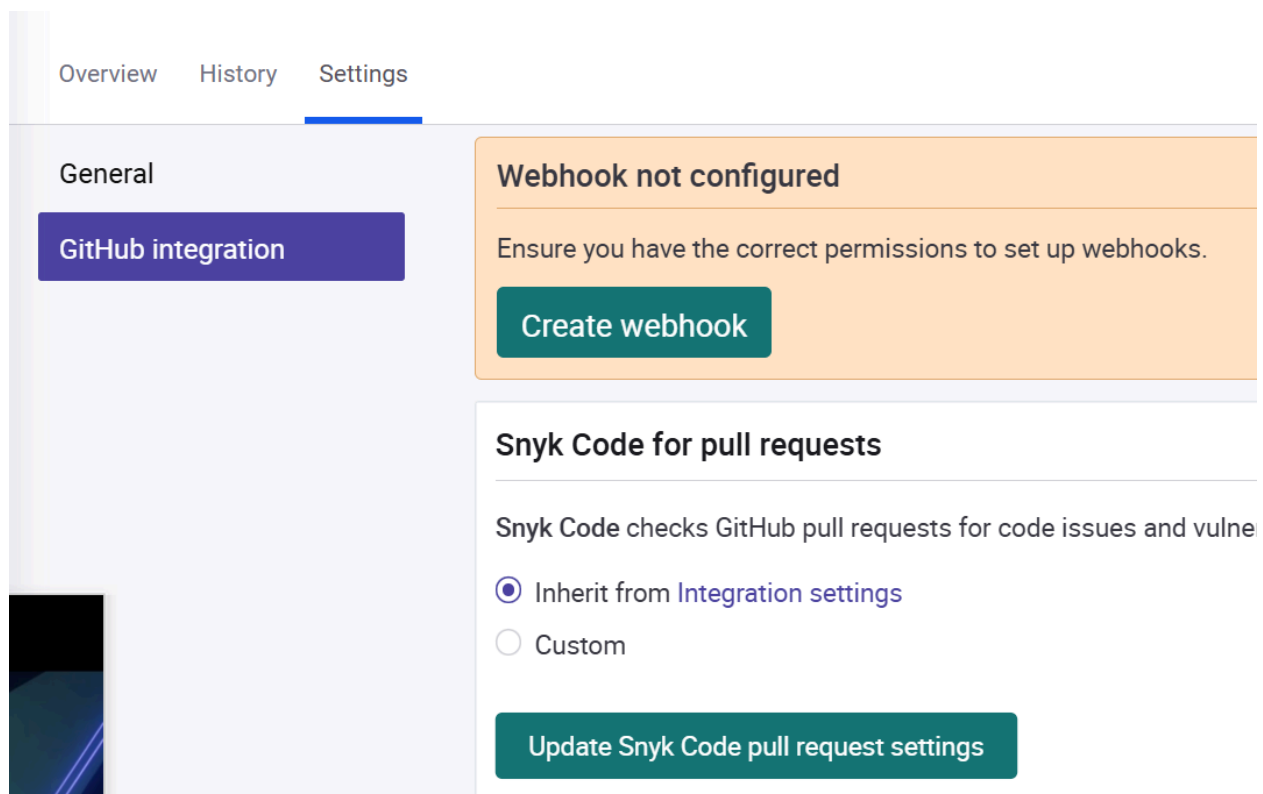
- On each issue there is detailed analysis with *Fix analysis* option, that provides examples on how to fix issues, best practices and examples.



5. But the code analysis did not touch all files. Bellow is the list of unsupported extensions.

- **Unanalyzed files:**

.html1, 1, .css5, .db1, .dist2, .dockerignore1, .gitattributes1, .gitignore1, .htaccess1, .ico1, .ini1, .jpg5, .json1, .lock1, .md21, .pdf1, .png9, .sql5, .txt3, .yaml8, .png1



6. Also In the settings for a project, I can set periodical updated on security as well as integration to Github's pulls and request (webhooks)

Created Thu 16th Oct 2025 | Snapshot for commit [4aa0c38](#) taken by snyk.io 16 minutes ago | [Retest now](#)

7. Analysis is made for snapshot of repo connected

DVNA

Repositories				
Search repositories by name ...				
Repository	Group	Code Analysis	Code Coverage	SCA
DVNA-clone	Default	• INACTIVE	• INACTIVE	• INACTIVE

1. I picked my new cloned repo and opened it inside deepsource.

Activate analysis on this repository

This repository is not activated, generate a new config or activate the repository directly if a `.deepsource.toml` already exists.

Generate config

Activate repository

2. Then I need to generate / activate repository for deepsource analysis via creating ,

CORE ANALYZERS



Ansible



C#



C & C++



Docker



Go



Java



JavaScript



Kotlin



PHP



Python



Ruby



Rust



Scala



Secrets



Shell



SQL



Swift



Terraform



Test coverage

COMMUNITY ANALYZERS



ADDITIONAL SETUP REQUIRED



AWS CloudFor...



Dart Analyze



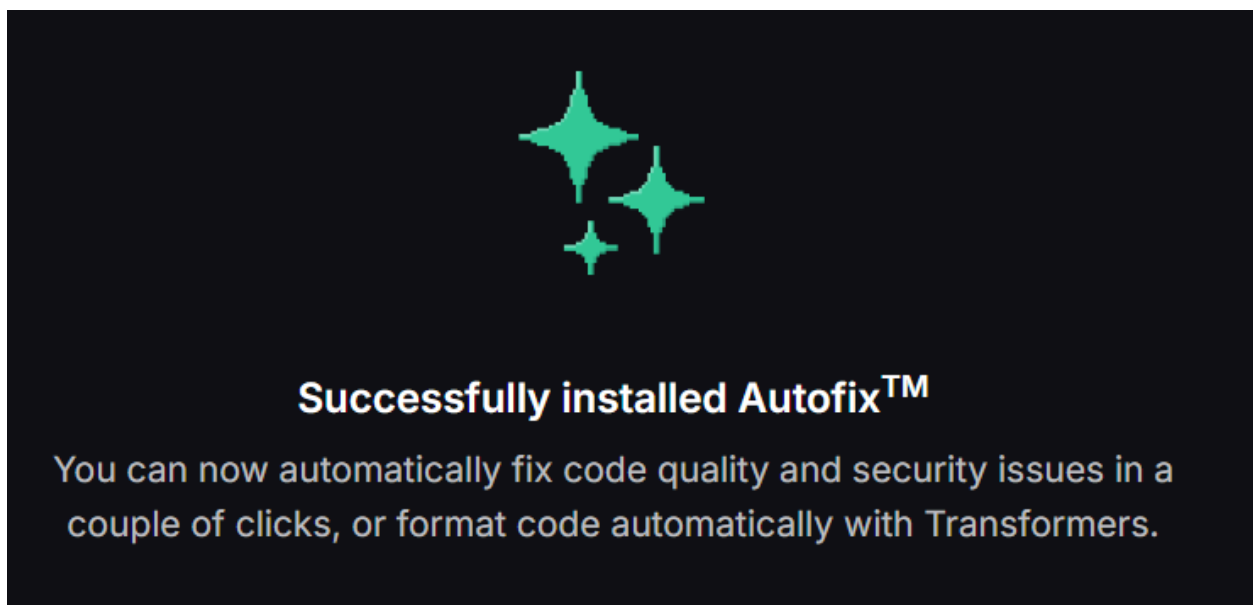
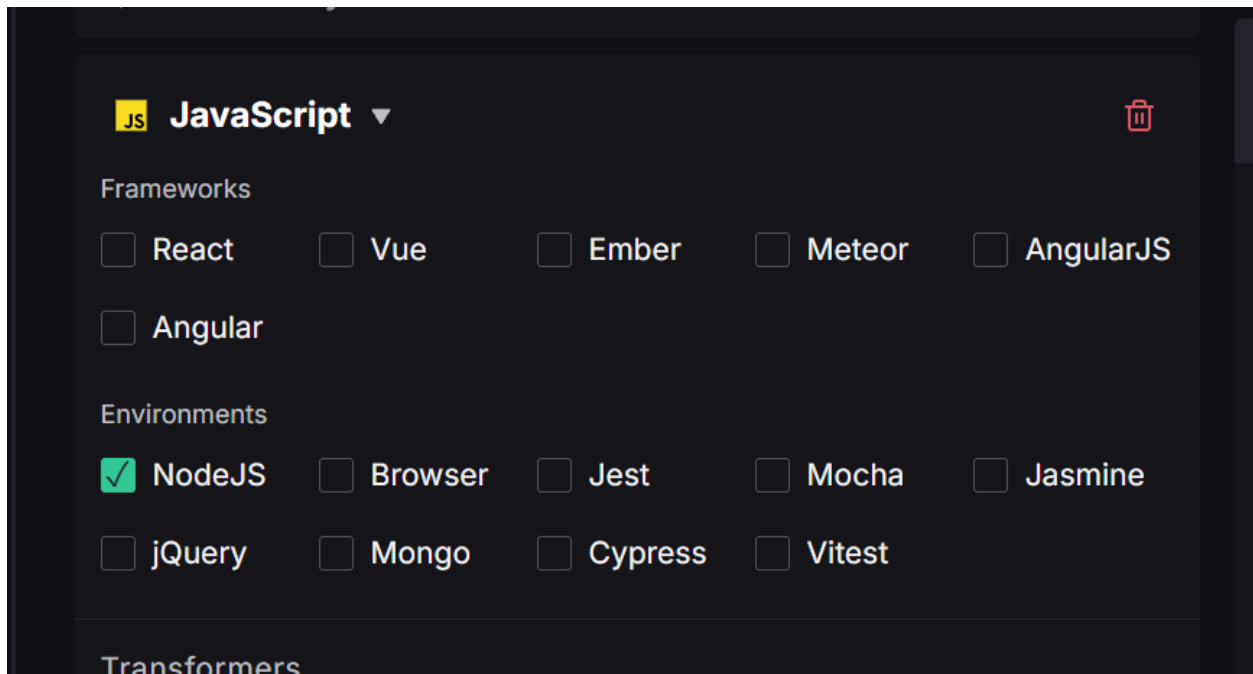
KubeLint



Slither



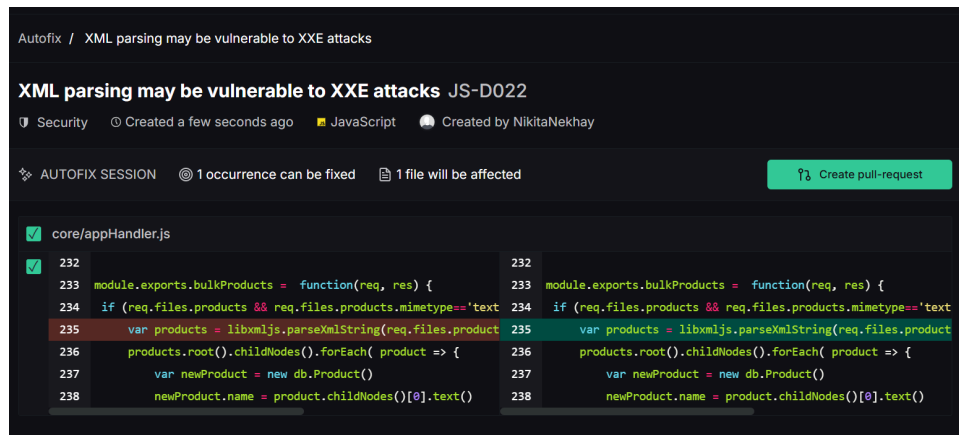
Solhint



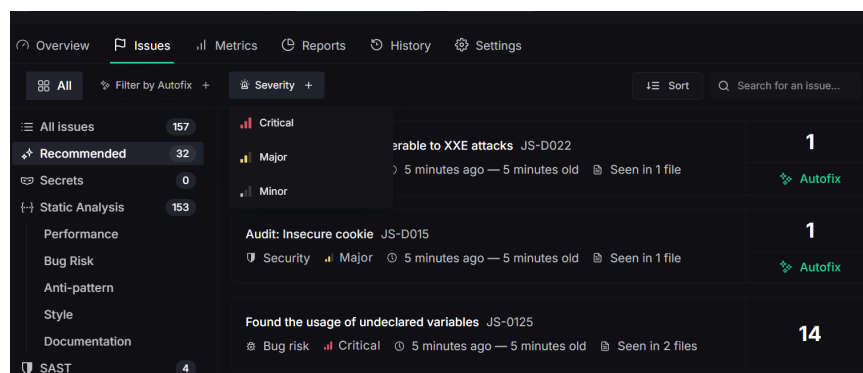
3. Generation of deepsource requires:
 - a. choosing analysers for codes and techs (languages → frameworks → environments)
 - b. choosing patterns. Patterns are allow to include/exclude files to analysis, e.g. ignore tests and auto-generated files — to improve accuracy and performance.

c. allowing auto commit options via installing **Autofix**

4. deepsource runs static analysis automatically on every commit and flags issues such as security vulnerabilities, bug risks, anti-patterns, performance problems, and style violations.
5. Performs Software Composition Analysis (SCA) to inspect dependencies, detect vulnerabilities, and suggest remediation paths.
6. Maintains a low false-positive rate through advanced post-processing filters.



7. Supports Autofix — automated suggestions or commits for simple, fixable issues.



BAD PRACTICE

```
const serialize = require('node-serialize')
let content = serialize.unserialize(someC

const { parse } = require('teleport-javas
const parsed = parse(stringified)
```

RECOMMENDED

```
const parsed = JSON.parse(stringified)
```

REFERENCES

- [OWASP A08:2021 - Software and Data Integrity Failures](#)
- [OWASP A08:2017 - Insecure Deserialization](#)
- [Deserialization Cheat Sheet](#)

8. Displays results in a detailed dashboard with issue lists, severity levels, file locations, and educational links with references on main standards.
9. Supports baseline analysis, surfacing only new issues in pull requests while keeping existing ones in the dashboard.

General

Configuration

Code Coverage

Quality gates

Issue priority

Badges

Ignore rules

Audit log

Quality Gates

Configure quality gates for your repository.

Pull Request Comments

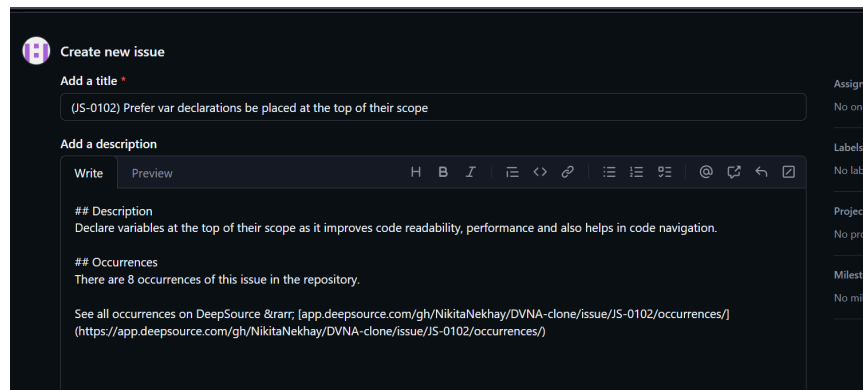
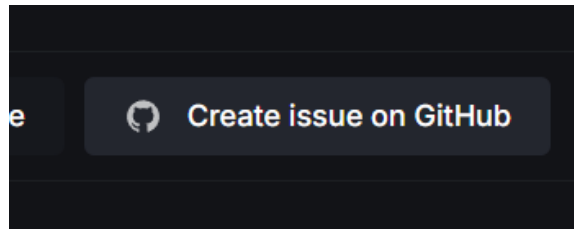
DeepSource will comment on the pull request with a summary of the analysis.

☒

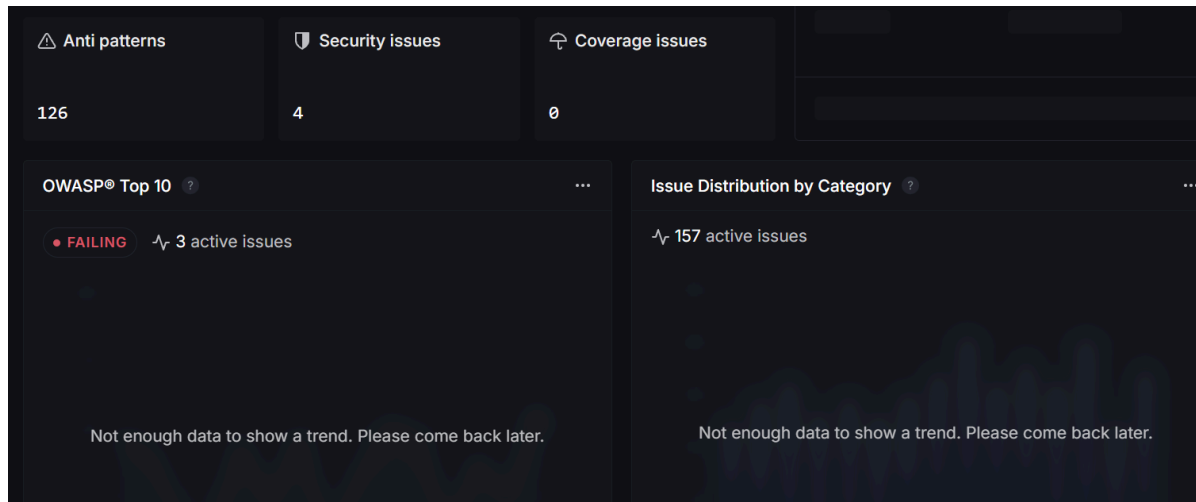
Issues

Configure the category and priority of issues that are reported and mark analysis runs as failed for blocking pull requests on GitHub.

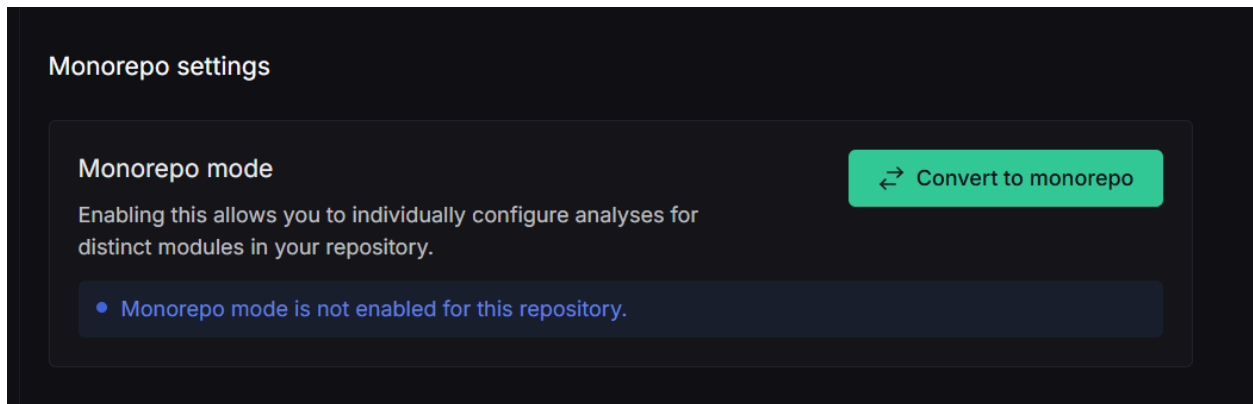
10. Enforces quality and security gates that can block pull requests not meeting set thresholds.



11. Integrates with tools like GitHub, Slack, and issue trackers for streamlined workflow automation. Also there is ability to directly create issues into project in the github



12. Provides metrics and reporting on code health, security posture, and historical trends.



13. Supports both multi-repository and monorepo project management within a single workspace.
14. Offers enterprise-grade features such as SSO, SAML, audit logs, and self-hosted deployment options.

DeepSource stands out because it combines static analysis and dependency (SCA) scanning with a very low false-positive rate, reducing noise compared to tools like SonarQube or ESLint. Its Autofix feature automatically commits fixes for simple issues, saving developers time and maintaining code quality continuously. Additionally, it integrates seamlessly with GitHub pull requests and CI pipelines, offering real-time feedback and clear dashboards that make code improvement faster and more actionable.

? As a conclusion. It is better to use multiple tools to SCA. Firstly I would set up and configure deepsource and gitlabs tools, that provide good integrity on CI/CD, then manually I would do analysis with different tools like sonar. But not all tools provide good analysis on specific tech stacks, for example even deepsource does not support all popular js frameworks.